

Reporte Técnico: Proyecto NOVASHOP

Responsable: Maria Mercedes Segura Hernández – Network Security Tester

Alcance: Infraestructura Física, Red Core/Acceso y Aplicación Web

Marco de Referencia: ISO/IEC 27001 (A.8.12) y Ley 8968 (Costa Rica)

Marco de Evaluación e Introducción

Objetivo y Alcance Técnico

Como responsable de las pruebas de seguridad bajo mi rol de Network Security Tester, el objetivo primordial es garantizar que la infraestructura física y virtual de NovaShop sea resistente ante amenazas y mantenga la continuidad del negocio. El perímetro de evaluación abarca:

- Infraestructura de Red: Análisis de la topología (segmentos de acceso y core) e inspección de switches Catalyst y servidores Dell R450.
- Auditoría de Protocolos: Evaluación de protocolos críticos como HTTPS, SSH, y protocolos de gestión como ARP, SNMP e ICMP priorizando la transición a versiones seguras.
- Flujo de Datos y Aplicaciones: Mapeo desde la aplicación web hasta las bases de datos internas para localizar puntos de falla o interceptación.
- Aplicaciones: Mapeo desde la aplicación web hasta las bases de datos internas para localizar puntos de interceptación o falla.
- Seguridad Física y Operacional: Inspección de cuartos de servidores, Racks (42U), sistemas UPS (APC) y videovigilancia con cámaras Meraki MV.

Nota de referencia: Para mayor detalle sobre los criterios técnicos, alcances específicos y límites operativos, puede consultar el documento: Plan de Evaluación de NovaShop en el anexo A.

Metodología de Auditoría

El proceso se divide en una metodología estructurada que garantiza la trazabilidad y el cumplimiento de estándares internacionales como ISO/IEC 27001. Esta se ejecuta en colaboración con analistas de vulnerabilidades, riesgos e infraestructura en cuatro fases clave:

Fase 1 (Reconocimiento): Revisión de diagramas, inventario detallado de activos (IAM, Directorio Activo) y levantamiento de la segmentación lógica actual.

Fase 2 (Escaneo): Pruebas activas de conectividad y escaneo de puertos para determinar vectores de ataque reales.

Fase 3 (Remediación): Validación técnica de controles de infraestructura ,bajo el modelo Zero Trust (microsegmentación y cifrado total).

Fase 4 (Validación): Protección de la capa de aplicación (WAF) y despliegue de monitoreo proactivo (PRTG).

Compromiso Ético y Exclusiones

Para asegurar la integridad de la operación comercial de NovaShop, la auditoría se rige por los siguientes límites éticos:

- Sin Explotación Real: El enfoque es la identificación y el análisis técnico profesional; no se ejecutan ataques que comprometan la disponibilidad de los servicios (DoS).
- Sin Ingeniería Social: Queda fuera del alcance cualquier intento de manipulación del personal para obtener credenciales.
- Entornos Controlados: No se realizan cambios de configuración en entornos productivos; toda simulación es teórica o en ambientes controlados para evitar alteraciones en la infraestructura real.

Diagnóstico Técnico y Hallazgos Críticos

El proceso de diagnóstico se fundamentó en el Proceso de Gestión de Vulnerabilidades, ejecutando una evaluación profunda en la Red Interna, la Zona Desmilitarizada (DMZ) y los servicios en la nube (AWS). Se utilizaron herramientas de diagnóstico proactivas como Nmap (descubrimiento), Wireshark (análisis de protocolos), NSLookup (integridad DNS) y Cisco CLI para validar la configuración de los activos.

Detalle de Hallazgos por Vector de Ataque

A través de las pruebas de conectividad y el análisis de la topología, se categorizaron las siguientes debilidades:

- Infraestructura de Red (Core): Se identificó que el switch central funciona como un Punto Único de Falla (SPOF). Un fallo en este componente provocaría el cese total de las operaciones y ventas de la sede física.
- Segmentación y Movimiento Lateral: Las VLANs (10, 20, 60 y 110) carecen de limitaciones de comunicación interna. Esto permite que una estación de trabajo comprometida pueda acceder directamente al Servidor SQL (192.168.110.100) a través del puerto 1433/TCP, el cual se detectó abierto y sin filtros.

- Inseguridad en Protocolos de Gestión: Se interceptaron credenciales administrativas viajando en texto plano mediante el uso de Telnet (Puerto 23). Asimismo, se confirmó la susceptibilidad a ataques de ARP Spoofing, permitiendo la interceptación de tráfico en los teléfonos IP 8841.
- Resiliencia Física y Continuidad: Los servidores Dell R450 dependen de un sistema UPS con carga crítica y carecen de un protocolo de apagado ordenado (Graceful Shutdown), lo que pone en riesgo la integridad de las bases de datos ante apagones.

Inventario de Activos y Criticidad de la Red

Para contextualizar los hallazgos, se clasificaron los componentes según su función técnica y nivel de riesgo para la continuidad de NOVASHOP:

ID	Nombre del Activo	Función Técnica y Criticidad	Dispositivo Físico	Ubicación / Segmento
ID-01	Nodo Central (Core)	Crítico (SPOF): Ruteo inter-VLAN. Punto único de falla detectado.	1xCisco Catalyst 9500	Capa de Núcleo
ID-02	Switches Distribución	Alta: Agregación de tráfico y aplicación de políticas.	Cisco Catalyst 9300	Capa de Distribución
ID-03	Switches de Acceso	Media: Conectividad en sectores Adm, Operaciones y TI.	10xCisco Catalyst 9200	Capa de Acceso
ID-04	SGBD / Servidores	Crítico: Datos sensibles, SQL y virtualización.	3x Dell PowerEdge R450	VLAN 110 (Servidores)
ID-05	Telefonía IP	Media: Voz corporativa. Vulnerable a sniffing.	35x Cisco Phone 8841	VLAN 60 (Voz)
ID-06	Respaldo Energía	Alta: Garantía de continuidad ante fallos eléctricos.	UPS APC Smart-UPS	Centro de Datos / Rack
ID-07	Seguridad (FW)	Crítico: Control de tráfico externo e inspección DMZ.	2x Cisco Firepower 1000	Borde de Red (Edge)
ID-08	Vigilancia IP	Baja/Física: Monitoreo perimetral y seguridad física.	Cámaras Meraki MV	VLAN 100 (CCTV)

Matriz de Hallazgos y Análisis de Riesgos

A continuación, se detallan las vulnerabilidades identificadas que comprometen la tríada de la seguridad (Confidencialidad, Integridad y Disponibilidad):

ID	Activo Afectado	Vulnerabilidad Técnica (Enfoque Infraestructura)	Vector de Ataque	CVSS	Severidad
R1	ID-01	Punto Único de Falla (SPOF): Ausencia de redundancia en el Core de red.	AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	9.1	Crítica
R2	ID-01 / ID-04	Movimiento Lateral: Falta de ACLs y microsegmentación inter-VLAN.	AV:A/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N	8.8	Alta
R3	ID-03	Gestión Insegura: Uso de Telnet/HTTP (Protocolos en texto plano).	AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H	8.4	Alta
R4	ID-05	Suplantación de Identidad (MitM): Falta de inspección dinámica de ARP.	AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N	7.5	Alta
R5	ID-07 / ID-04	Exposición de Servicio Crítico: Puerto 1433 expuesto por falta de WAF/IPS.	AV:N/AC:L/PR:N/UI:N/S:C/C:C/H/I:H/A:H	9.8	Crítica
R6	ID-07	Acceso no Autorizado: Falta de MFA en el perímetro (Firepower).	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	8.2	Alta
R7	ID-06	Riesgo de Continuidad: Sobrecarga y estrés térmico en el UPS.	AV:P/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	7	Media
R8	ID-07	Vulnerabilidad de Resolución: Falta de DNSSEC en la zona externa.	AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N	6.5	Media

Detalle de Pruebas de Concepto y Evidencias

Interceptación y Escalada de Privilegios (R3 y R4)

En el Sector Operaciones, se utilizó Wireshark para capturar tráfico de gestión. Se recuperaron credenciales administrativas ,enviadas en texto plano por el puerto 23 (Telnet). Además, se inyectaron paquetes ARP gratuitos, logrando que el tráfico de voz de un teléfono 8841 (ID-05) fuera redirigido a la estación del auditor, confirmando la vulnerabilidad a ataques Man-in-the-Middle.

Exposición de Datos y Movimiento Lateral (R2 y R5)

Se confirmó que estaciones de trabajo no autorizadas pueden saltar directamente al servidor SQL:

- Prueba: nmap -sV -p 1433 192.168.110.100 resultando en Open.
- Falla de Aplicación: El sistema de ventas en los servidores Dell (ID-04) no sanitiza entradas, permitiendo inyecciones como ' OR 1=1 -- que revelan la estructura interna de la base de datos de NOVASHOP.

Fallo de Continuidad Crítica (R1 y R7)

El núcleo de la red (ID-01) carece de mecanismos de alta disponibilidad. Paralelamente, los sensores IPMI en los servidores Dell detectaron temperaturas de

32°C, mientras que el UPS (ID-06) solo garantiza 4 minutos de autonomía. Esta combinación pone en riesgo inminente la integridad del hardware y de las bases de datos ante cualquier interrupción eléctrica o de hardware.

Soporte Documental y Evidencias Técnicas

Los hallazgos presentados en esta sección son el resultado de un proceso de auditoría técnica basado en el Proceso de Gestión de Vulnerabilidades. Cada vulnerabilidad aquí listada cuenta con la justificación técnica que valida su existencia y potencial impacto en la infraestructura de NOVASHOP.

Para una revisión exhaustiva de todo el proceso de auditoría , consulte el anexo B: Reporte de Identificación de Vulnerabilidades.

Estrategia de Remediación y Ejecución Técnica

En esta fase, se transformaron los hallazgos del diagnóstico en soluciones operativas, aplicando el marco de referencia ISO/IEC 27001 (A.8.12). La estrategia se dividió en tres ejes fundamentales para garantizar la defensa en profundidad de NOVASHOP.

Eje de Disponibilidad: Alta Disponibilidad y Resiliencia

El objetivo primordial fue eliminar el Punto Único de Falla (R1) y asegurar la continuidad ante incidentes eléctricos (R7).

- Implementación de StackWise-480: Se configuró un clúster lógico con los dos switches Cisco Catalyst 9500 (ID-01). Mediante esta tecnología, ambos dispositivos operan como una sola entidad. Si el switch activo falla, el secundario asume el tráfico en milisegundos, manteniendo las ventas activas.
- Redundancia de Servidores (LACP Distribuido): Se configuró la agregación de enlaces para los servidores Dell PowerEdge R450. Al conectar cada servidor a ambos nodos del Stack, se garantiza que el acceso a la base de datos SQL sea ininterrumpido.
- Protocolo de Apagado Ordenado (Graceful Shutdown): Se integró el software PowerChute con la UPS APC (ID-06). Al detectar un 15% de batería restante, el sistema cierra automáticamente los servicios de base de datos antes del corte total, evitando la corrupción de datos.

Eje de Confidencialidad: Endurecimiento (Hardening) y Cifrado

Se neutralizaron los riesgos de interceptación de tráfico (R3 y R4) y exposición de gestión insegura.

- Migración a Gestión Segura (SSH v2 / HTTPS): Se deshabilitaron definitivamente Telnet (P23) y HTTP (P80). Ahora, toda administración de los switches Catalyst 9200 (ID-03) viaja cifrada, impidiendo que herramientas como Wireshark capturen credenciales administrativas.
- Defensa en Capa 2 (DHCP Snooping y DAI): Se activó la inspección dinámica de ARP en las VLANs de Voz y Datos. Esto impide ataques de *ARP Spoofing*, asegurando que la identidad de los teléfonos IP 8841 y estaciones de trabajo no sea suplantada.
- Aislamiento de Voz y QoS: Se separó el tráfico de telefonía en una VLAN de Voz con prioridad de servicio, haciendo que las comunicaciones sean invisibles para el segmento de datos.

Eje de Integridad: Microsegmentación y Protección de Datos

Se atacó el riesgo de movimiento lateral (R2) y ataques a la capa de aplicación (R5).

- Microsegmentación SQL: Se implementaron ACLs Extendidas en el núcleo de la red. Actualmente, el acceso al puerto TCP 1433 del Servidor de Base de Datos está restringido exclusivamente a la dirección IP del servidor de aplicaciones, bloqueando cualquier intento de conexión desde otros segmentos.
- Firewall de Aplicación Web (WAF): Se activaron reglas de inspección profunda en el Cisco Firepower (ID-06) para detectar y bloquear intentos de Inyección SQL (SQLi), protegiendo la integridad de la tienda virtual.
- Protección DNSSEC: Se habilitó la firma digital en las zonas DNS para garantizar que los clientes de NOVASHOP siempre lleguen al portal legítimo, eliminando el riesgo de envenenamiento de caché.

Nota Técnica: Para la implementación detallada de comandos, scripts de configuración y validaciones línea por línea, consulte el Anexo C: Guía de Remediación Técnica al final de este documento.

Reporte Técnico-Ejecutivo y Cierre

La culminación de este proyecto de fortalecimiento de red marca la transición de una infraestructura reactiva a una postura de seguridad proactiva. A continuación, se detallan los resultados finales, el modelo de visibilidad implementado y las recomendaciones para preservar la integridad de NOVASHOP S.A.

Conclusión de la Postura de Seguridad (Post-Remediación)

Tras la validación de los controles, se ha logrado reducir el riesgo residual a niveles aceptables para el negocio. La infraestructura ahora cuenta con:

- Disponibilidad Determinista: Gracias a StackWise-480, la red es capaz de sobrevivir a fallos críticos de hardware en el Core sin interrupción de servicios.
- Confidencialidad Blindada: Se eliminó el riesgo de captura de credenciales administrativas y se protegió la privacidad de las comunicaciones de voz (VLAN 60).
- Integridad de Datos: La combinación de WAF y Microsegmentación garantiza que el activo más valioso (Base de Datos SQL) esté aislado de vectores de ataque laterales y externos.

Monitoreo Proactivo y Visibilidad Continua

Para garantizar que los controles implementados se mantengan operativos, se han desplegado los siguientes sistemas de telemetría:

- Visibilidad de Red (PRTG Network Monitor): Se configuraron sensores SNMP y Netstat en los servidores Dell R450. El sistema generará alertas automáticas si se superan los umbrales de 300 conexiones simultáneas (detección de DoS) o si la temperatura del rack excede los 30°C.
- Seguridad Física Meraki MV: Las cámaras inteligentes ahora cuentan con análisis de movimiento activo sobre el rack de comunicaciones. Cualquier apertura física del gabinete generará una notificación inmediata vía Webhook al equipo de TI, garantizando la trazabilidad forense.
- Centralización de Eventos (Syslog): Todos los dispositivos (Catalyst, Firepower y WAF) envían sus registros de seguridad al servidor 192.168.99.50, asegurando que los logs sean inmutables y estén disponibles para futuras auditorías.

Recomendaciones de Mejora Continua

Para cumplir con el control A.8.8 de ISO 27001 sobre la gestión de vulnerabilidades técnicas, se recomienda:

- Auditoría Trimestral: Realizar escaneos programados con Nmap para asegurar que no se hayan habilitado puertos inseguros accidentalmente.
- Gestión de Parches: Establecer una ventana de mantenimiento mensual para la actualización de firmas de amenazas en el Cisco Firepower.
- Simulacros de Resiliencia: Ejecutar pruebas semestrales de conmutación de energía para validar que el software PowerChute siga realizando el cierre ordenado de las bases de datos.

Declaración de Cierre Técnico

El proyecto de fortalecimiento de la Infraestructura de Red - NOVASHOP, se da por finalizado satisfactoriamente. Los vectores de ataque críticos identificados en el diagnóstico han sido mitigados mediante la implementación de controles técnicos de última generación, alineando a la organización con los mejores estándares de ciberseguridad industrial.

Firma:

Maria Mercedes Segura Hernández

Network Security Tester Costa Rica, Marzo 2026

Sección de Anexos

- Anexo A: Plan de Evaluación NovaShop .
- Anexo B: Reporte de Identificación de Vulnerabilidades.
- Anexo C: Guía de Remediación Técnica.